

Understanding Cyber Attacks



Attack Vectors

- **Traditional Attack Vectors:**

- Viruses
- Worms
- Trojans
- Spyware
- Wiper
- Malwares
- Bots

- **New Attack Vectors:**

- Attack Vectors:
 - Phishing
 - Insider Threat
 - Credential Attacks

Labs

- Students to analyze the given malware analysis link and answer the questions
- Students will learn to create phishing links

Malwares

- Malware (**Malicious Software**) refers to any software intentionally designed to disrupt, damage, steal data, or gain unauthorized access to computer systems, networks, or devices.
- Major Types of Malware:
 - **Virus** - Attaches to legitimate files or programs
 - **Worm** - Self-replicates and spreads automatically
 - **Trojan** - Disguises as legitimate software
 - **Ransomware** - Encrypts files and demands payment
 - **Spyware** - Secretly monitors user activity
 - **Adware** - Displays unwanted advertisements
 - **Rootkit** - Hides malware activity
 - **Botnet Malware** - Turns systems into remotely controlled bots
 - **Wiper** - Permanently destroys data
 - **Fileless Malware** - Resides in memory



How Malware Enters Systems

- Phishing emails
- Malicious downloads
- Unpatched vulnerabilities
- Infected USB devices
- Compromised credentials

Impact of Malware

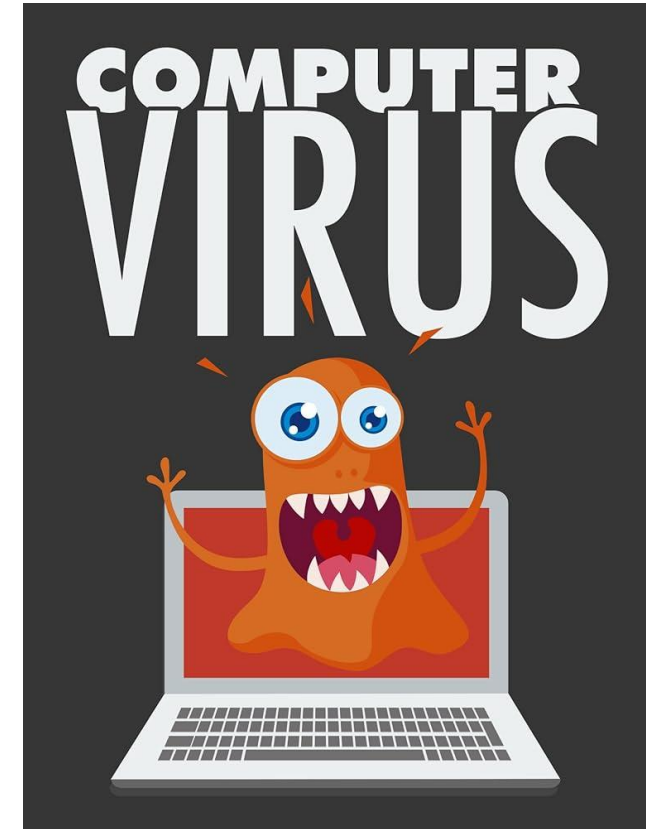
- Data loss or theft
- Financial damage
- Business downtime
- Legal and compliance risks
- Reputation loss

Prevention and Protection

- Regular patching and updates
- Antivirus and EDR (Endpoint Detection and Response) deployment
- Network firewalls and IDS/IPS
- User awareness training
- Secure backups and recovery plans

Viruses

- A computer virus is a type of malicious software (malware) that attaches itself to legitimate files or programs and replicates when the infected file is executed, spreading from one system to another without the user's knowledge or consent.
- Key Characteristics of a Virus
 - **Self-replicating:** Copies itself by infecting other files or programs
 - **Host-dependent:** Requires a legitimate host file or application to execute
 - **User action required:** Typically spreads when a user runs an infected file
 - **Payload delivery:** Can perform harmful actions after activation

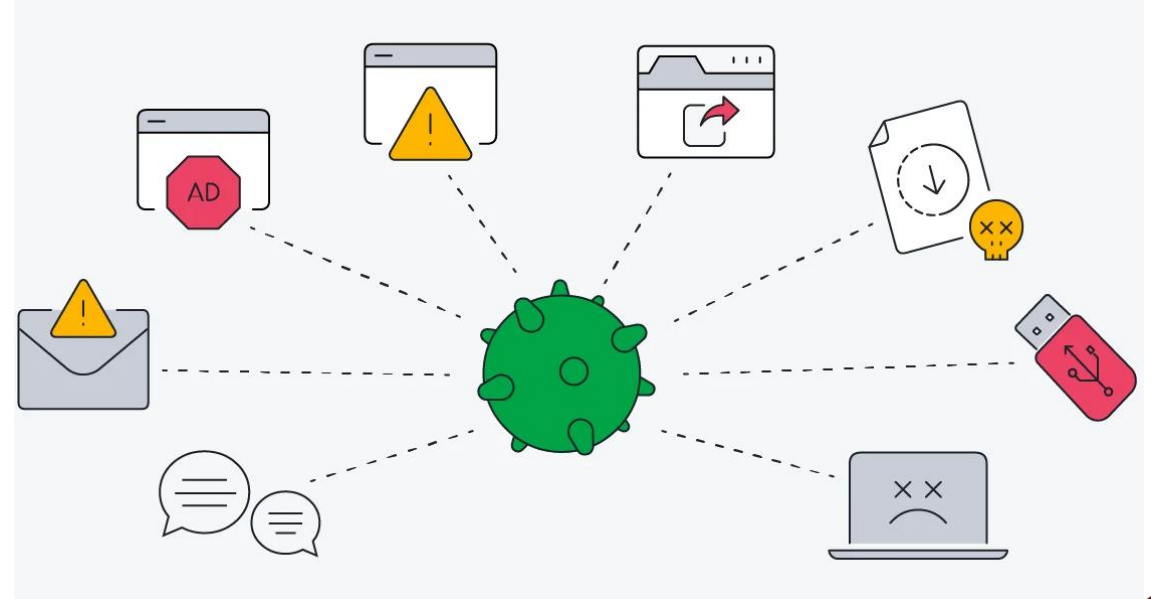


How a Virus Works & Spread

1. Virus embeds itself into a legitimate file or program
2. User executes the infected file
3. Virus code runs and replicates
4. Virus spreads to other files or systems
5. Payload activates (data corruption, system damage, etc.)

Virus spreads using:

- Email attachments
- Infected software downloads
- Removable media (USBs)
- File sharing and pirated software
- Infected document with macros.



Types of Computer Viruses

Virus Type	Description
File Infector Virus	Attaches to executable files
Boot Sector Virus	Infects system boot records
Macro Virus	Infects documents using macros (Word, Excel)
Resident Virus	Stays in memory and infects files continuously
Non-Resident Virus	Executes, infects, then exits memory
Polymorphic Virus	Changes its code to evade detection
Multipartite Virus	Infects multiple parts of a system



Worms

- A computer worm is a type of malicious software (malware) that can self-replicate and spread automatically across networks without requiring any user action or a host file.
- Key Characteristics of Worms
 - Self-propagating: Spreads on its own
 - No host file required: Does not attach to legitimate programs
 - Network-aware: Exploits network vulnerabilities
 - Fast spreading: Can infect thousands of systems rapidly
- **Famous Worms:**
 - Morris Worm
 - Conficker
 - WannaCry (worm-like ransomware)



Working of Worm & Payload

1. Worm scans networks for vulnerable systems
2. Exploits a software or protocol vulnerability
3. Gains access to the target system
4. Replicates itself
5. Spreads to other systems automatically

▪ **Common Payloads of Worms:**

- Network congestion and denial of service
- Installing backdoors or botnet agents
- Dropping additional malware (ransomware, trojans)
- Data destruction or modification



Types of Computer Worms

Worm Type	Description
Network Worm	Spreads via network vulnerabilities
Email Worm	Spreads via email contacts automatically
Internet Worm	Exploits internet-facing services
File-Sharing Worm	Spreads through shared files and drives
Mobile Worm	Targets smartphones and IoT devices

Prevention and Protection

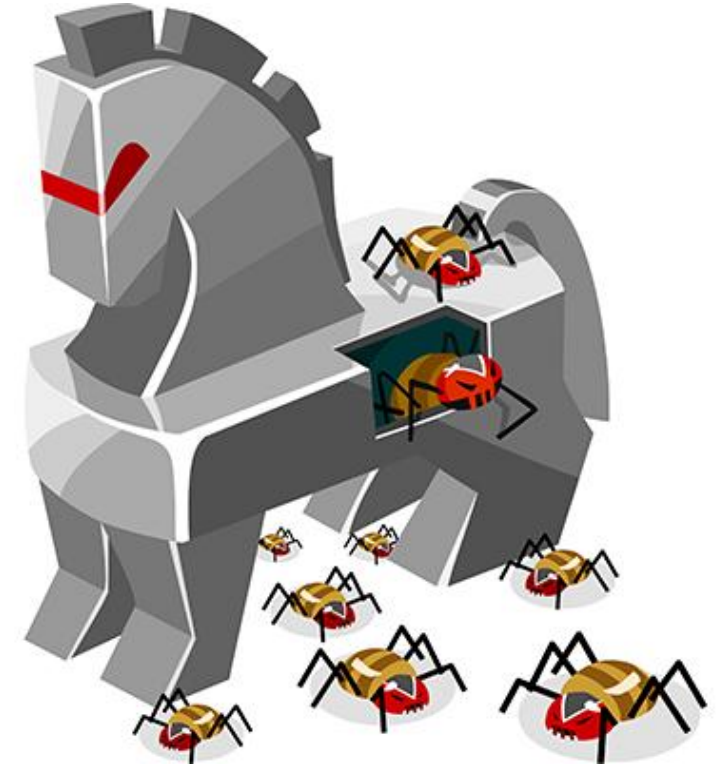
- Patch operating systems and applications
- Use firewalls and network segmentation
- Deploy IDS/IPS and EDR solutions
- Disable unnecessary services and ports
- Monitor network traffic for anomalies

Trojans

- A Trojan (Trojan Horse) is a type of malicious software (malware) that disguises itself as legitimate or useful software to trick users into installing or executing it.
- Unlike viruses and worms, Trojans do not self-replicate.

Why It Is Called a “Trojan Horse”?

- The name comes from the Greek Trojan Horse—a *deceptive gift that appeared harmless but delivered attackers inside a fortified city.*
- Similarly, a Trojan looks safe but performs malicious actions once inside the system.

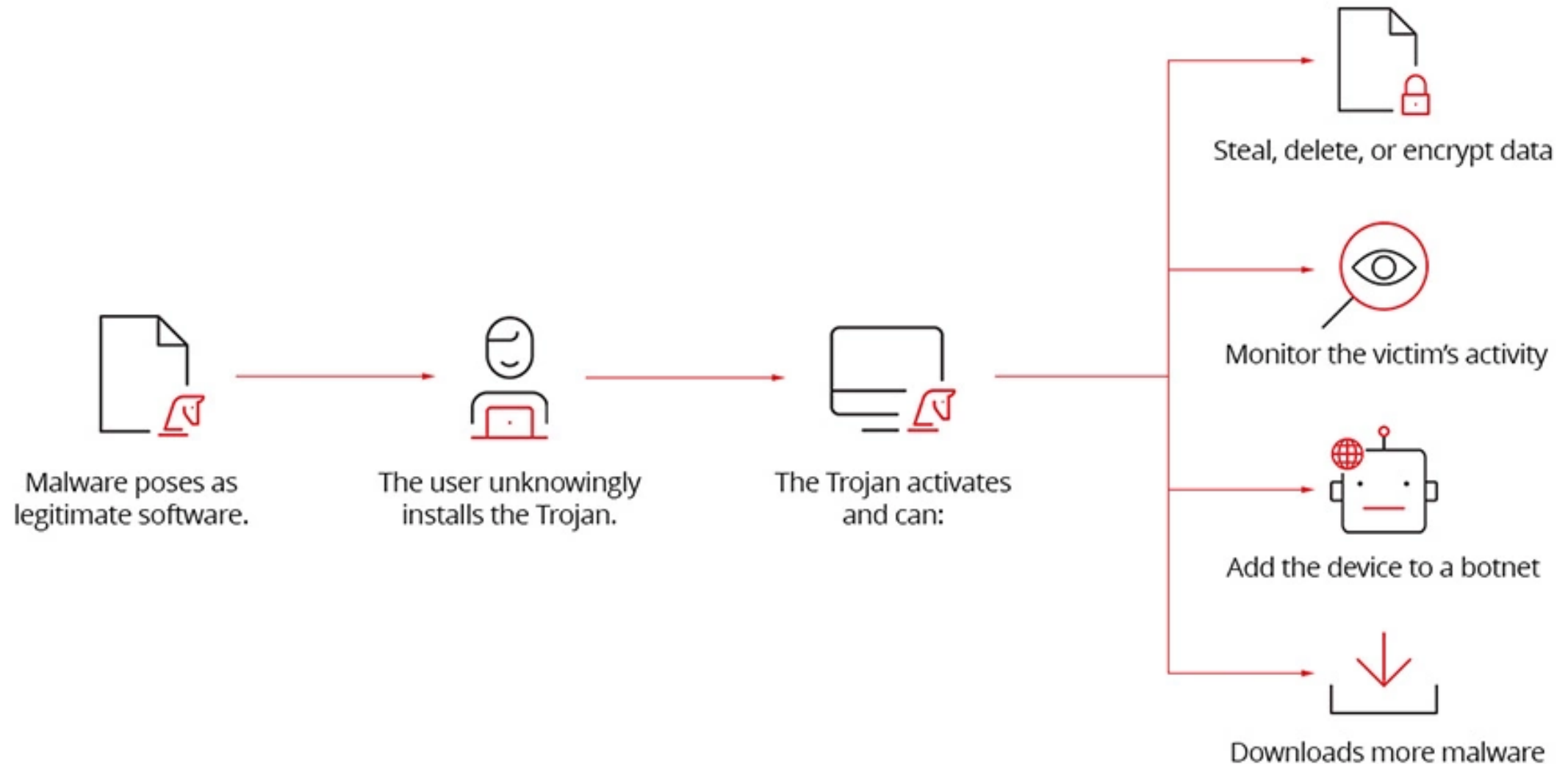


Key Characteristics of Trojans

- Disguised as legitimate software
- Requires user action (installation or execution)
- Does not self-replicate
- Often acts as a delivery mechanism for other malware
- Trojans Spread via:
 - Phishing emails and attachments
 - Fake software updates
 - Cracked or pirated software
 - Malicious websites
 - Infected USB drives



How a Trojan Works?



Types of Trojans

Trojan Type	Description
Backdoor Trojan	Provides remote control to attackers
Banking Trojan	Steals financial and login data
Downloader Trojan	Downloads additional malware
RAT (Remote Access Trojan)	Full remote access to victim system
Spy Trojan	Monitors user activity
Fake AV Trojan	Pretends to be antivirus software
Dropper Trojan	Installs hidden malware components



Trojan vs Virus vs Worm

Aspect	Trojan	Virus	Worm
Disguised as legitimate	Yes	No	No
Self-replicating	No	Yes	Yes
User interaction required	Yes	Yes	No
Network-based spreading	No	Limited	Yes



Detection and Prevention

- Educate users about phishing and fake software
- Download software only from trusted sources
- Use updated antivirus/EDR solutions
- Apply application whitelisting
- Monitor network and endpoint behavior

Spyware

- Spyware is a type of malicious software (malware) designed to *secretly monitor, collect, and transmit information* about a user or system without the user's knowledge or consent.
- Its primary objective is **data theft**, not system damage.
- Key Characteristics of Spyware
 - ✓ **Stealthy operation:** Runs silently in the background
 - ✓ **Data-focused:** Collects sensitive user and system information
 - ✓ **Persistent:** Often designed to remain undetected for long periods
 - ✓ **Privacy-invasive:** Violates user privacy



SPYWARE



Information collected by Spyware:

- Login credentials and passwords
- Banking and credit card details
- Browsing history
- Email content and contacts
- Screenshots and keystrokes
- System configuration details



Types of Spyware

Spyware Type	Description
Keylogger	Records keystrokes to steal credentials
Adware	Tracks browsing behavior for targeted ads
System Monitor	Captures system activity and screenshots
Infostealer	Steals stored credentials and sensitive files
Tracking Cookies	Tracks online behavior (borderline spyware)
Mobile Spyware	Targets smartphones and tablets

How Spyware Enters Systems ?

- Bundled with free or pirated software
- Phishing emails and malicious attachments
- Drive-by downloads from compromised websites
- Fake software updates
- Infected USB devices

Impact of Spyware

- Identity theft
- Financial fraud
- Loss of privacy
- Corporate data leakage
- Compliance and legal violations

Detection and Prevention

- Use updated antivirus and EDR solutions
- Enable real-time system monitoring
- Avoid untrusted software downloads
- Keep operating systems and browsers patched
- Use browser security extensions
- Educate users on phishing awareness

Detection, Prevention & Enterprise Considerations

- Use updated antivirus and EDR solutions
- Enable real-time system monitoring
- Avoid untrusted software downloads
- Keep operating systems and browsers patched
- Use browser security extensions
- Educate users on phishing awareness

Enterprise Considerations

- ✓ Deploy DLP (Data Loss Prevention)
- ✓ Monitor outbound network traffic
- ✓ Enforce least-privilege access
- ✓ Regular endpoint audits

Wiper

- A Wiper is a type of destructive malware designed to *permanently delete, overwrite, or corrupt data and system components*, rendering systems unusable and unrecoverable.
- Unlike ransomware, wipers do not seek financial gain—their primary objective is sabotage and disruption.



Key Characteristics of Wiper Malware

- **Data destruction focused:** Permanently erases files, disks, or boot records
- **No recovery intent:** Does not provide a decryption or restoration mechanism
- **Often targeted:** Used in geopolitical, military, or sabotage campaigns
- **Highly destructive:** Can cripple entire organizations in minutes
- Common Destructive Actions
 - Overwriting files with random data or zeros
 - Deleting partition tables
 - Destroying boot loaders (MBR/GPT)
 - Corrupting firmware or system configuration
 - Disabling backups and shadow copies



Types of Wiper Malware

Wiper Type	Description
Disk Wiper	Overwrites entire disks or partitions
File Wiper	Targets specific files or directories
Boot Wiper	Destroys boot records to prevent startup
Firmware Wiper	Corrupts BIOS/UEFI (rare but severe)
Network Wiper	Spreads laterally to wipe multiple systems

How Wiper spreads?

- Phishing emails and malicious attachments
- Compromised admin credentials
- Exploited vulnerabilities
- Supply chain compromises
- Lateral movement within networks

Famous Wiper Attacks:

- **Shamoon** – Targeted energy sector
- **NotPetya** – Disguised as ransomware, acted as a wiper
- **HermeticWiper** – Used in geopolitical conflicts

Impact of Wiper Attacks

- Total loss of data
- Prolonged business outages
- Costly recovery and system rebuilds
- National infrastructure disruption
- Reputational and operational damage

Prevention and Mitigation

- Strong identity and access management
- Network segmentation and least privilege
- Offline, immutable backups
- Endpoint Detection and Response (EDR)
- Rapid incident response and isolation
- Regular disaster recovery testing

Bots

- A Bot (robot) is a malicious program that runs automatically on an infected system and allows it to be remotely controlled by an attacker without the user's knowledge.
- A collection of such infected systems is called a Botnet.
- Key Characteristics of Bots
 - Operate silently in the background
 - Communicate with a Command-and-Control (C2) server
 - Execute commands automatically
 - Scale attacks using thousands or millions of infected devices



Types of Bots

Bot Type	Purpose
DDoS Bot	Overwhelms servers with traffic
Spam Bot	Sends massive spam/phishing emails
Credential Bot	Performs login attacks
Crypto Bot	Mines cryptocurrency
Proxy Bot	Routes attacker traffic anonymously
IoT Bot	Targets routers, cameras, IoT devices

How Bots Work ?

1. System is infected via malware (Trojan, worm, exploit)
2. Bot installs itself and persists
3. Bot connects to a C2 (Command-and-Control) server
4. Attacker sends commands
5. Bot executes tasks on demand

Impact of Bot Infections

- Network performance degradation
- Blacklisting of IP addresses
- Financial and operational losses
- Legal and compliance issues
- Use of infrastructure for criminal activity

Detection and Prevention

- Deploy EDR/XDR solutions
- Monitor outbound traffic for C2 communication
- Patch operating systems and firmware
- Enforce strong authentication
- Segment networks
- Use DDoS protection services

Well-Known Botnets

- *Mirai* – IoT botnet
- *Zeus* – Banking botnet
- *Emotet* – Modular botnet
- *Conficker* – Worm-bot hybrid

New Attack Vectors

- Attack Vectors:
 - ✓ Phishing
 - ✓ Insider Threat
 - ✓ Credential Attacks



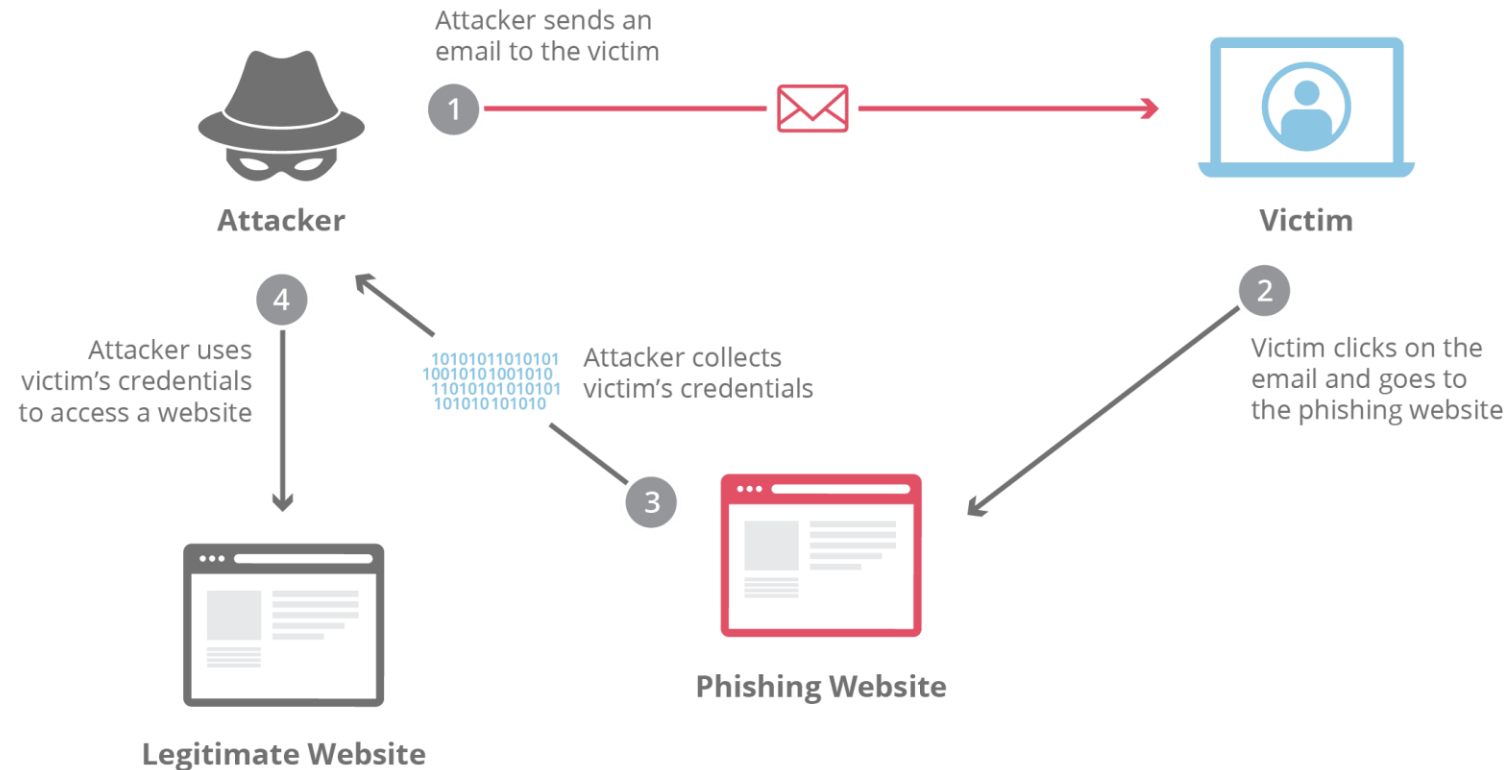
Phishing

- Phishing is a social engineering attack in which attackers impersonate a trusted entity to trick individuals into revealing sensitive information, such as login credentials, financial data, or personal details, or into installing malware.
- Phishing relies on human deception, not technical exploitation.
- Key Characteristics of Phishing
 - Uses spoofed identities (banks, employers, cloud providers)
 - Exploits urgency, fear, or curiosity
 - Delivered primarily via email, but also SMS, calls, and social media
 - Targets individuals, employees, and enterprises



How Phishing Works

- Attacker crafts a deceptive message
- Message impersonates a trusted source
- Victim receives the message
- Victim clicks a link, opens an attachment, or responds
- Credentials, data, or access is compromised



Common Phishing Techniques

- Fake login pages
- Malicious attachments (PDF, DOC, ZIP)
- URL spoofing and look-alike domains
- Brand impersonation
- Account suspension or invoice fraud messages



Types of Phishing

Phishing Type	Description
Email Phishing	Mass fraudulent emails
Spear Phishing	Targeted attacks on specific individuals
Whaling	Targets executives and senior leaders
Smishing	Phishing via SMS
Vishing	Voice-based phishing calls
Clone Phishing	Legitimate email modified maliciously



Impact of Phishing Attacks

- Credential theft
- Financial fraud
- Malware and ransomware infections
- Business Email Compromise (BEC)
- Data breaches and compliance violations

Enterprise Best Practices

- Conduct regular phishing simulations
- Enforce least privilege access
- Monitor login anomalies (UEBA)
- Rapid incident response for credential compromise

Detection and Prevention

- User awareness and security training
- Email security gateways
- Multi-Factor Authentication (MFA)
- URL filtering and DNS security
- EDR/XDR integration
- Domain monitoring and DMARC/DKIM/SPF

Why Phishing Is So Effective?

- Phishing succeeds because it exploits:
 - Human psychology, not software flaws
 - Trust in brands, authority, and urgency
 - Gaps between technical controls and human behavior
- Over 80–90% of breaches begin with some form of phishing or credential abuse in enterprise environments.

Advanced Phishing Techniques (Modern Attacks)

- **Credential Harvesting**

- Fake Microsoft 365, Google, VPN, or HR portals
- Real-time capture of usernames, passwords, and MFA tokens

- **Business Email Compromise (BEC)**

- No malware involved
- Uses trusted email threads
- Leads to wire fraud, invoice fraud, payroll diversion

- **OAuth Phishing**

- Malicious cloud app requests permissions
- Bypasses password and MFA entirely

- **QR-Code Phishing (Quishing)**

- QR codes embedded in emails or posters
- Bypasses email link inspection tools

- **MFA Fatigue Attacks**

- Repeated MFA push requests
- User eventually approves out of frustration

Insider Threat

- An Insider Threat is a security risk that originates from within the organization, caused by individuals who have authorized access to systems, data, or facilities and misuse that access, either intentionally or unintentionally.
- Insiders may be employees, contractors, vendors, or partners.
- **Why Insider Threats Are Dangerous:**
 - Bypass perimeter defenses
 - Use legitimate credentials
 - Hard to detect with traditional security tools
 - Often persist for long periods (high dwell time)



Types of Insider Threats

Type	Description
Malicious Insider	Intentionally steals, sabotages, or leaks data
Negligent Insider	Causes harm through mistakes or poor security hygiene
Compromised Insider	Legitimate account taken over by external attackers

Insider Threat Attack Lifecycle

- Legitimate access is established
- Trust is abused or account is compromised
- Sensitive data or systems are accessed
- Data is misused, leaked, or destroyed
- Organization detects (often late)

Impact of Insider Threats

- Intellectual property theft
- Financial fraud
- Data breaches
- Regulatory non-compliance
- Operational disruption
- Reputation damage



Detection and Prevention

▪ People

- Background checks
- Security awareness training
- Clear acceptable-use policies

▪ Process

- Least privilege access
- Separation of duties
- Joiner–Mover–Leaver (JML) controls
- Regular access reviews

▪ Technology

- UEBA (User & Entity Behaviour Analytics)
- DLP (Data Loss Prevention)
- PAM (Privileged Access Management)
- EDR/XDR
- SIEM correlation



Credential Attacks

- Credential attacks are cyber-attacks in which adversaries **steal, guess, reuse, or abuse authentication credentials (usernames, passwords, tokens, keys)** to gain unauthorized access to systems, applications, or data.
- They are one of the most common initial access vectors in modern breaches.
- Why Credential Attacks Are So Effective:
 - Password reuse across services
 - Weak or default credentials
 - Lack of Multi-Factor Authentication (MFA)
 - Credentials are easier to steal than exploit software
 - Legitimate logins evade many security controls



Common Types of Credential Attacks

Attack Type	Description
Phishing	Tricking users into revealing credentials
Credential Stuffing	Using leaked credentials across multiple sites
Brute Force	Systematically guessing passwords
Password Spraying	Trying common passwords across many accounts
Keylogging	Capturing keystrokes via malware
Man-in-the-Middle (MITM)	Intercepting credentials in transit
Token Theft	Stealing session cookies or OAuth tokens
MFA Fatigue	Abusing push-based MFA approvals



Credential Attack Lifecycle

- Credential Harvesting (phishing, malware, leaks)
- Credential Validation (testing logins quietly)
- Account Compromise
- Privilege Escalation
- Lateral Movement
- Persistence
- Actions on Objectives (data theft, ransomware, fraud)



Impact of Credential Compromise

- Full account takeover
- Cloud tenant compromise
- Business Email Compromise (BEC)
- Data breaches
- Ransomware deployment
- Regulatory and financial losses



Prevention and Mitigation

■ Identity Controls

- Enforce phishing-resistant MFA (FIDO2, passkeys)
- Disable legacy authentication
- Strong password policies
- Credential hygiene and rotation

■ Monitoring

Detection

- UEBA for behaviour anomalies
- SIEM correlation rules
- Conditional access policies
- Login risk scoring

&

■ Endpoint & Network

- EDR to detect credential dumping
- Block LSASS access
- Secure remote access gateways





That's all Folks!